

Caso prático InterMed

Caso base e exercício do Módulo 1 (matriz de McFarlan) · Ciclo do Negócio de Cibersegurança

Documento disponibilizado exclusivamente para uso dos formandos desta formação. Os exercícios seguintes do caso são publicados nas páginas dos respetivos módulos.

1. Caso de estudo — InterMed & Digital

Contexto geral da InterMed

A InterMed é um grupo privado de saúde com hospitais, clínicas, centros de diagnóstico e serviços ambulatoriais, suportado por uma base tecnológica heterogénea, construída ao longo do tempo por aquisições, crescimento orgânico e múltiplas decisões locais de investimento em sistemas.

A nova administração assumiu recentemente funções com uma agenda clara de crescimento, eficiência operacional e transformação digital, pretendendo acelerar canais digitais, integração de dados, relacionamento com doentes, parcerias B2B e novos serviços digitais em saúde.

O novo CEO considera que a transformação digital é um vetor central da estratégia, mas entende também que a capacidade de execução da InterMed pode não estar ao nível da ambição estratégica.

Existem dúvidas sobre a maturidade interna para suportar uma agenda intensa de mudança: os processos de governação tecnológica são pouco uniformes, a arquitetura aplicacional é fragmentada, a dependência de terceiros é elevada e as equipas internas têm sinais de escassez em áreas críticas, sobretudo cibersegurança, arquitetura, gestão de serviço e gestão de fornecedores.

Neste contexto, a organização enfrenta riscos de execução estratégica relevantes. A nova estratégia digital exige que projetos de modernização, interoperabilidade, aplicações online, analytics, cloud e IA avancem com maior rapidez, mas a InterMed ainda revela um modelo organizacional tradicional, com Segurança da Informação integrada em IT, baixa integração entre áreas e fraca articulação entre risco corporativo, compliance, operações e tecnologia. A NIS2 reforça precisamente a necessidade de governação, gestão de risco, monitorização, segurança da cadeia de fornecimento, secure development e reporting ao órgão de gestão, o que torna mais visível a distância entre a ambição estratégica e a maturidade atual.

O novo CEO pediu também uma informação mais direta, executiva e acionável sobre a gestão da cibersegurança. Em vez de relatórios excessivamente técnicos, pretende receber uma visão sintética sobre exposição ao risco, dependências críticas, nível de maturidade, decisões prioritárias e impacto no negócio. Esta alteração de expectativa executiva cria uma oportunidade para reposicionar a cibersegurança como tema de gestão e de execução estratégica, e não apenas como função técnica dentro do IT.

2. Modelo estratégico CISO da InterMed (Matriz de McFarlan) — exercício do Módulo 1

A InterMed opera um conjunto alargado de sistemas de informação (SI) que suportam cuidados de saúde, back-office, relação com doentes, integração com pagadores e processos administrativos. A nova estratégia digital quer acelerar canais digitais, analytics, integração de dados clínicos e operacionais e novas propostas de valor para parceiros e doentes, mas a organização ainda não dispõe de um modelo claro para diferenciar os sistemas que apenas suportam eficiência daqueles que são críticos para operar hoje ou determinantes para competir amanhã.

Neste contexto, a administração pediu ao responsável de segurança, em articulação com IT e com o negócio, um exercício simples de leitura estratégica dos sistemas através da Matriz de McFarlan. O objetivo é perceber que sistemas são apenas de suporte, quais são operacionais e críticos para a continuidade, quais têm potencial transformador e quais já são estratégicos. Para o CISO, este exercício é útil porque ajuda a ligar criticidade, risco, prioridade de controlo, dependência de terceiros e narrativa executiva sobre investimento.

Entre os sistemas em análise estão o Dossier Clínico Eletrónico (DCE), o sistema de agendamento, a gestão de camas e bloco operatório, o ERP financeiro e de compras, o portal do doente, a app móvel, a plataforma de BI, o RH, o email, o sistema de faturação, as integrações com seguradoras, soluções cloud e serviços de suporte. A dificuldade é que a InterMed não tem ainda um modelo unificado de classificação de criticidade, nem critérios estáveis que cruzem impacto operacional, impacto clínico, receita, reputação, obrigações legais, dependência de terceiros e relevância estratégica.

Acresce que a baixa maturidade organizacional torna o exercício mais complexo e mais útil. Algumas áreas classificam sistemas apenas com base na sua importância local; outras focam-se no custo; outras ainda confundem inovação com criticidade. Não existe uma taxonomia partilhada sobre o que é «crítico», não há consenso sobre tolerância à indisponibilidade e as dependências de terceiros são pouco transparentes. A aplicação da matriz deve, por isso, ser usada também como instrumento de alinhamento entre negócio, IT, risco e cibersegurança.

Dados adicionais para análise

- O DCE suporta assistência clínica diária e integra prescrição, exames e histórico.
- O portal do doente cresceu 40% no último ano e o CEO quer duplicar a adoção digital em 18 meses.
- O sistema de faturação tem impacto direto em receita e convenções.
- O BI é visto como base para decisões de eficiência, expansão e performance.
- O ERP é importante, mas vários processos ainda conseguem fallback parcial.
- O email é relevante, mas não é elemento diferenciador do negócio.
- Vários sistemas críticos dependem de fornecedores externos e cloud.
- Não existe inventário completo de interdependências aplicacionais.

Questões

- 1 Classifique os sistemas na Matriz de McFarlan.
- 2 Justifique a posição de cada sistema com base em impacto atual e impacto futuro.
- 3 Identifique o principal risco cyber por quadrante.
- 4 Associe a cada quadrante o principal driver de decisão do CISO.
- 5 Explique como a matriz pode apoiar o reporting executivo ao CEO.

Checklist de apoio

- O sistema é crítico para operar hoje?
- O sistema é relevante para competir amanhã?
- A sua falha afeta cuidado clínico, receita ou reputação?
- Existe forte dependência de terceiros?
- Há fallback ou workaround?
- O sistema trata dados de saúde ou outros dados sensíveis?
- O sistema é alvo provável de requisitos reforçados de continuidade e monitorização?
- O sistema é visto pela administração como alavanca estratégica?
- A classificação é partilhada entre negócio, IT e segurança?

Folha de resposta

Sistema	Quadrante	Risco cyber dominante	Driver de decisão
DCE			
Agendamento			
Faturação			
ERP			
Portal do doente			
App móvel			
BI			
RH			
Email			

Nota: a resposta a este exercício entrega-se na Ficha de Trabalho do Módulo 1 (disponível na página do módulo).